

GLOBAL CLOUD INFRASTRUCTURE & DATA SECURITY POLICY

Document ID: POL-SEC-2026-V4

Classification: Confidential – Internal Enterprise Standard

Framework Alignment: SOC 2 Type II (CC6.1, CC6.6, CC6.7, CC7.1, A1.2) | ISO/IEC 27001:2022 (A.5.15, A.8.1, A.8.7, A.8.12, A.8.24)

Effective Date: January 1, 2026

1. Purpose & Scope

This policy defines mandatory baseline security, governance, and operational resilience configurations for all cloud assets, virtual infrastructure, managed databases, and storage containers deployed within enterprise AWS accounts. Compliance with these controls is mandatory across all environments (Production, Staging, and Development).

2. Object Storage Governance (Amazon S3)

- **SEC-S3-001: Mandatory Server-Side Encryption**
- All Amazon S3 storage buckets must enforce server-side encryption at rest using AWS Key Management Service or AES-256 (`server_side_encryption in ['aws:kms', 'AES256']`). Creation or operation of unencrypted buckets is strictly prohibited.
- **SEC-S3-002: Public Access Prevention**
- Public read, write, and list permissions must be universally blocked on all S3 buckets. Both `block_public_acls` and `block_public_policy` configurations must evaluate to `true`.
- **SEC-S3-003: Versioning for Regulated Data**
- Where bucket classification is tagged as `regulated_data` (`data_classification == 'regulated_data'`), bucket versioning must be enabled (`versioning_status == 'Enabled'`) to ensure object immutability and recovery against accidental modification.
- **SEC-S3-004: Enforce Secure Transport (TLS 1.2+)**
- All S3 bucket policies must explicitly deny HTTP requests and enforce TLS transmission (`secure_transport == true`).

3. Database Infrastructure & Resiliency (Amazon RDS)

- **SEC-RDS-001: Storage Encryption at Rest**
- All Amazon RDS database instances and clusters must have storage encryption enabled (`storage_encrypted == true`) using approved customer-managed KMS keys.
- **SEC-RDS-002: Production High Availability**

- For all RDS database instances operating in the production environment (`environment == 'production'`), Multi-AZ deployment must be active (`multi_az == true`) to guarantee failover availability.
- **SEC-RDS-003: Automated Backup Retention Period**
- Automated point-in-time recovery backup retention (`backup_retention_days`) must be configured to be greater than or equal to 7 days (`backup_retention_days >= 7`).
- **SEC-RDS-004: Restrict Public Accessibility**
- Database instances must not be assigned public IP addresses; `publicly_accessible` must be explicitly set to `false`.

4. Compute Workloads & Virtual Machine Baseline (Amazon EC2)

- **OPS-EC2-001: Compute Resource Utilization & Capacity**
- Under standard operating baseline conditions, virtual compute instances must maintain average CPU utilization below 85 percent (`cpu_utilization < 85`).
- **SEC-EC2-002: IMDSv2 Token Access Enforcement**
- All running EC2 instances must enforce Instance Metadata Service Version 2 to mitigate Server-Side Request Forgery vulnerabilities (`http_tokens == 'required'`).
- **SEC-EC2-003: EBS Boot & Data Volume Encryption**
- All Elastic Block Store (EBS) volumes attached to compute instances must enforce encryption at rest (`ebs_encrypted == true`).

5. Identity, Access Management & Auditability (IAM & CloudTrail)

- **SEC-IAM-001: Multi-Factor Authentication (MFA)**
- All IAM user accounts with console access privileges must have virtual or hardware MFA activated (`mfa_enabled == true`).
- **SEC-LOG-001: Multi-Region Audit Logging**
- AWS CloudTrail logging must be enabled across all AWS regions with global service event capture active (`cloudtrail_multi_region == true`).